



TryNex Lifestyle

SECURITY AUDIT REPORT

Authentication, rate limiting, CSRF, CSP, secrets rotation, and vulnerability assessment

Generated: May 14, 2026 · Confidential · trynexshop.com

Helmet 8	HSTS, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy	PASS
CORS Policy	Allow list only, credentials: true, no wildcard origins	PASS
Rate Limiting — Auth	20 req / 15 min per IP on POST /api/admin/login	PASS
Rate Limiting — Orders	30 req / 15 min per IP on POST /api/orders	PASS
Rate Limiting — Reviews	5 req / 10 min per IP on POST /api/reviews	PASS
Rate Limiting — Public	200 req / 5 min per IP on all GET endpoints	PASS
Rate Limiting — Tracking	20 req / 5 min per IP on /orders/track	PASS
CSRF Protection	X-Requested-With header enforcement on mutations	PASS
JWT — Admin	ADMIN_JWT_SECRET (separate from customer JWT)	PASS
JWT — Customer	JWT_SECRET (separate secret required)	PASS
Password Hashing — Admin	argon2 (memory-hard, GPU-resistant)	PASS
Password Hashing — Customer	bcrypt (cost factor 10)	PASS
Admin TOTP 2FA	RFC 6238, database-stored secrets, optional per admin	PASS
Admin Session Table	tokenHash stored (not raw token), expiry, revocation	PASS
Input Validation	Zod schemas on all API inputs (server-side)	PASS
SQL Injection Prevention	Drizzle ORM parameterised queries only	PASS
XSS Prevention	React JSX encoding + DOMPurify for rich text	PASS
Upload Validation	Content-type check + size limit on file uploads	PASS
Trust Proxy	trust proxy: 1 for correct IP behind Cloudflare/Render	PASS
Env Validation	Hard exit at startup if required secrets missing in prod	PASS
No Secrets in Bundle	All env vars server-side only, never in frontend	PASS
Cloudflare WAF	DDoS protection, bot management at CDN layer	PASS
data-cf-ray="false"	Prevents Cloudflare Rocket Loader breaking scripts	PASS

CRITICAL	GitHub PAT (ghp_K9...rXzT)	Was used in session — ROTATE IMMEDIATELY	
CRITICAL	ADMIN_PASSWORD	admin is used in dev — must change before prod	
HIGH	JWT_SECRET	Ensure 32+ char random string, unique to prod	Before deploy
HIGH	ADMIN_JWT_SECRET	Must differ from JWT_SECRET entirely	Before deploy
HIGH	R2_ACCESS_KEY_ID	Verify not leaked in logs or commits	Before deploy
HIGH	R2_SECRET_ACCESS_KEY	Verify secure — never committed	Before deploy
HIGH	UPSTASH_REDIS_REST_TOKEN	Verify secure — rotate if shared	Before deploy
MEDIUM	CLOUDFLARE_API_TOKEN	Verify least-privilege scope (Pages + R2 only)	Week 1
MEDIUM	RENDER_API_KEY	Verify not committed anywhere in repo	Week 1
MEDIUM	DATABASE_URL_MAIN	Verify Neon connection string is correct format	Week 1
LOW	SMTP_USER / SMTP_PASS	Configure for order email notifications	Week 2
LOW	TELEGRAM_BOT_TOKEN	Configure for admin order alerts	Optional
LOW	GOOGLE_CLIENT_ID	Configure for Google OAuth login	Optional

SQL Injection	LOW — Drizzle ORM parameterised queries, no raw SQL	Mitigated
XSS — Stored	LOW — React JSX escaping + DOMPurify on TipTap output	Mitigated
XSS — Reflected	LOW — No server-side rendering of user input	Mitigated
CSRF	LOW — X-Requested-With enforcement + SameSite cookies	Mitigated

Brute Force — Admin	LOW — 20/15min rate limit + argon2 + 2FA available	Mitigated
Brute Force — Customer	MEDIUM — bcrypt present, 2FA not yet for customers	Accepted
JWT Token Leakage	LOW — Bearer token in header only, not in URL or cookie	Mitigated
Order Enumeration	LOW — Track requires orderNumber + phone match	Mitigated
File Upload Abuse	MEDIUM — R2 not yet configured; local fallback active	Accepted
API Abuse	LOW — Rate limiting on all public endpoints	Mitigated
Secret Exposure in Repo	MEDIUM — GitHub PAT was used in session (rotate now)	Action required
Missing MFA	LOW — TOTP 2FA available for admin, optional	Accepted
Dependency Vulnerabilities	LOW — pnpm audit shows no critical CVEs	Monitor